

From Attack to Fix: Secure Web Review

The capstone exercise

You know the OWASP menu. Now execute a mini-assessment start-to-finish on a lab web app you control – DVWA, bWAPP, or one you scaffold.

Engagement it

Scope: one app instance, all features, write down exclusions

Enumerate: robots.txt, headers, tech stack, endpoint inventory (ffuf/gobuster)

Map flows: login, search, profile – where do inputs cross trust boundaries?

Test the OWASP set: authZ, injection, crypto, misconfig, components, sessions, logging, SSRF

Prioritize: 3 findings max, evidence-heavy

Fix: patch the source (parameterize, encode output, centralize authz)

Re-test: confirm the exploit no longer works; no regressions

The disciplined table

#	Layer	Finding	OWASP	Severity	Repro	Fix
1	App	SQLi in search	A03	High	union payload	parameterized
2	App	Stored XSS	A03	High	script in guestbook	encode output
3	Auth	Weak session cookie	A07	Med	HttpOnly off	flags

Code-review pass (after fixing)

SELECT with parameters everywhere? (grep for concat/query-string building)

All user output through escape helpers?

Authz middleware: one place, called for every object access?

Secrets: .env only, gitignored?

Uploads stored outside webroot with magic-byte checks?

CSP header set; dependency audit green?

Deliverable

A one-page executive summary + detailed appendix (repro, evidence, validation). This exercise = your first 'right-handed' piece of proficiency proof.

You now hold the whole cycle: attack → prove → explain → fix → re-verify. That loop is what 'application security engineer' means in practice.

[← Business Logic Flaws & AuthZ...](#)

Module complete ✓